

Request for Proposal

Enterprise Risk Audit Modernisation

Internal programme reference: Risk Audit

Reference	AFG-RFP-2026-0147
Issued	19 June 2026
Clarification questions due	7 July 2026
Proposal deadline	24 July 2026, 17:00 CEST
Issued by	Procurement and Vendor Management, Auerbach Financial Group AG
Contact	procurement@auerbach-fg.example

1. Introduction and Background

Auerbach Financial Group AG ("Auerbach") is a diversified financial services provider headquartered in Frankfurt am Main. The firm offers retail and corporate banking, asset management, and insurance brokerage to roughly 1.4 million customers across Germany and Austria, and operates under the supervision of the Federal Financial Supervisory Authority (BaFin). Its activities fall within the full scope of MaRisk, the EU General Data Protection Regulation, and the Digital Operational Resilience Act (DORA).

Auerbach has grown over the past decade through several acquisitions. As a result, risk and control information is now spread across a range of legacy systems, spreadsheets, and team-specific tools. The current risk assurance process is largely manual: control owners submit evidence by email, auditors record findings in disconnected workbooks, and management reporting is assembled by hand each quarter. The approach is slow, hard to audit in its own right, and does not scale with the firm's regulatory commitments.

Auerbach is therefore launching a programme, known internally as Risk Audit, to modernise how the firm plans, performs, and reports on enterprise risk and control audits. The firm is seeking a delivery partner to design and implement a single, integrated capability that brings risk information together, automates routine control testing, manages the audit lifecycle from end to end, and produces dependable reporting for management and regulators. This document sets out the requirements for that engagement and the basis on which proposals will be assessed.

2. Objectives

The Risk Audit programme is intended to replace the firm's current patchwork of manual processes with one coherent platform that the second and third lines of defence can rely on. Auerbach wants to cut the effort needed to gather evidence and test controls, shorten the time taken to produce regulatory reporting, and improve the traceability of every audit decision. Above all, the firm wants a defensible and well-documented audit trail that demonstrates, to both BaFin and internal stakeholders, that its controls are operating as intended.

3. Scope of Work

The selected partner will be responsible for the design, build, integration, and rollout of the capability described below. The work is expected to span four broad areas. Each subsection sets out the outcome Auerbach expects; respondents should describe how they would achieve it and how their proposed architecture supports it.

3.1 Bringing risk information together

Today, a risk analyst who needs a complete picture of a single business unit has to pull data from at least four places by hand, and Auerbach needs this to stop. The selected partner is expected to connect the relevant source systems so that risk and control data flows into one place automatically. At a minimum this means establishing reliable interfaces to the core banking platform (Avaloq), the existing governance, risk and compliance register currently held in a legacy RSA Archer instance, the firm's policy management library, and the identity and entitlements directory that records who has access to what. Because each of these systems describes risks and controls differently, Auerbach also needs a common, consistent way of representing this information, so that a control recorded in one system can be reconciled against the same control referenced in another. Once the interfaces exist, the data cannot be a one-off load. The firm needs it refreshed on a regular schedule, with automated checks that flag where a feed has failed or where figures do not reconcile against their source. Stale or silently broken data will be treated as a defect.

3.2 Testing controls without doing it by hand

A large share of the firm's current audit effort goes into manually checking whether routine controls are being followed, and Auerbach wants this routine testing automated wherever the underlying evidence allows. The partner should maintain a structured library that records each control, the policy clause or regulatory obligation it satisfies, and the rule that determines whether it has passed. Working from that library, the solution should run tests automatically on a defined cadence, drawing on the evidence already consolidated under section 3.1 rather than waiting for control owners to attest by hand. Where a test fails, or where the supporting evidence is missing or ambiguous, the case must not vanish into a report. It needs to be raised as an exception and routed to the appropriate analyst for follow up, with the reason for the exception preserved alongside it. Auerbach expects that a meaningful share of low-judgement controls can be assessed in this way, releasing auditors to concentrate on the controls that genuinely require human judgement.

3.3 Running the audit and keeping the evidence

Beyond automated testing, Auerbach continues to perform structured audit engagements that involve people, and the platform must support that work from beginning to end. An audit lead should be able to plan an engagement, set its scope, assign it to named members of the audit team, and track it against agreed dates from within the system rather than in a separate workbook. As the engagement proceeds, the evidence gathered (documents, screenshots, system extracts, and sign-offs) must be stored against the relevant control in a way that cannot be quietly altered afterwards. Auerbach places particular weight on a tamper-evident record showing who supplied each piece of evidence and when, because this is exactly what an external examiner will ask to see. Findings raised during an engagement should move through a defined review and approval path, so that a junior auditor's conclusion is checked and signed off by a reviewer before it is treated as final, and any resulting remediation is recorded and tracked through to closure rather than lost once the audit is filed.

3.4 Reporting to management and regulators

The final area concerns what the organisation does with everything the platform gathers. Auerbach's leadership currently waits weeks for a quarterly risk picture that is already out of date by the time it lands, and the firm wants management to be able to see the current state of risk and control health at

any time, through a view that surfaces the firm's key risk indicators and shows how they are trending. Separately, and this is not optional for a regulated institution, the solution must be able to produce the formal report packs that BaFin and the firm's internal committees require, in the prescribed structure and format, without an analyst reassembling them by hand each cycle. Auerbach would also like the owner of a given risk to be alerted automatically when an indicator crosses a defined threshold, and for those reports and alerts to reach the right recipients on a set schedule, so that oversight never depends on someone remembering to send an email.

4. Technical and Security Requirements

The following constraints apply to any proposed solution. They are not themselves deliverables, but a proposal that cannot satisfy them will not be taken forward. The solution must be hosted within the European Union, and all customer and risk data must remain within EU jurisdiction at all times. Access must integrate with Auerbach's existing single sign-on provider over SAML 2.0 and must enforce role-based access, so that audit records are visible only to authorised staff. The platform is expected to be available throughout German business hours within the availability limits set out in Auerbach's internal service standards, and every access to an audit record must itself be logged. The proposed architecture should be consistent with DORA expectations for operational resilience.

5. Deliverables and Timeline

Auerbach expects the engagement to be delivered in phases, with a working consolidation and reporting capability in place before the more advanced automated testing features are introduced. The dates below are indicative and will be refined with the selected partner during mobilisation.

Milestone	Indicative date
Contract award	15 August 2026
Mobilisation and detailed design complete	30 September 2026
Risk information consolidation live	15 December 2026
Automated control testing live	27 February 2027
Audit lifecycle and reporting live	30 April 2027
Final acceptance	31 May 2027

6. Vendor Qualifications

Auerbach is looking for a partner with demonstrable experience delivering risk, audit, or compliance technology for regulated financial institutions in the DACH region or the wider European Union. Respondents should supply at least two comparable references from the past five years, describe the size and composition of the team they would assign, and confirm that key personnel are fluent in both German and English. Direct experience with BaFin-supervised institutions and familiarity with MaRisk and DORA will be regarded favourably.

7. Proposal and Evaluation

Proposals should address each area of the scope of work in section 3, set out the respondent's proposed approach and solution architecture, offer both a fixed-price and a time-and-materials commercial option, and include a project plan consistent with the indicative timeline. Submissions will be

assessed on the following basis:

Evaluation criterion	Weighting
Strength of the proposed solution against the requirements	40%
Relevant experience and references	20%
Commercial terms	20%
Team quality and key personnel	15%
Working-style and cultural fit	5%

8. Submission Instructions

Questions of clarification must be submitted in writing to procurement@auerbach-fg.example no later than 7 July 2026. Complete proposals must be received by 17:00 CEST on 24 July 2026 and submitted electronically to the same address. Late or incomplete submissions will not be considered. This document, and any information disclosed in connection with it, is confidential to Auerbach Financial Group AG and may not be shared with third parties without the firm's written consent.